

Guide NPC

쿠키 값 변조를 통한 권한 상승 및 정보 노출 (Cookie Tampering to Privilege Escalation)

TARGET problem06	PREPARED FOR 8low8lowme Team	SEVERITY: LOW
AUTHOR 김혜미	CWE CWE-565 · CWE-284	STATUS: FINAL

1. 개요 (Executive Summary)

problem06(Guide NPC)을 분석한 결과, 사용자의 권한 등급을 판별하는 로직이 서버 세션이 아닌 클라이언트가 보낸 쿠키(role) 값에 전적으로 의존하고 있음을 확인했다. 이 쿠키는 별도의 서명이나 무결성 검증 없이 사용자 권한 문자열을 base64로 인코딩만 해서 저장하고 있어, 브라우저 개발자 도구로 값을 디코딩하고 임의의 값으로 재인코딩해 재전송하는 것만으로 권한을 조작할 수 있었다.

서버(api/chat.php)는 이 쿠키 값이 사전에 정의된 권한자 목록(operator, admin, staff, developer, auditor)에 해당하는지만 확인하고, 요청이 실제로 인가된 세션에서 온 것인지는 검증하지 않았다. 결과적으로 별도의 인증 절차 없이 쿠키 문자열 하나만 바꾸는 것으로 관리자급 권한을 획득해 비밀 플래그를 노출시킬 수 있었다.

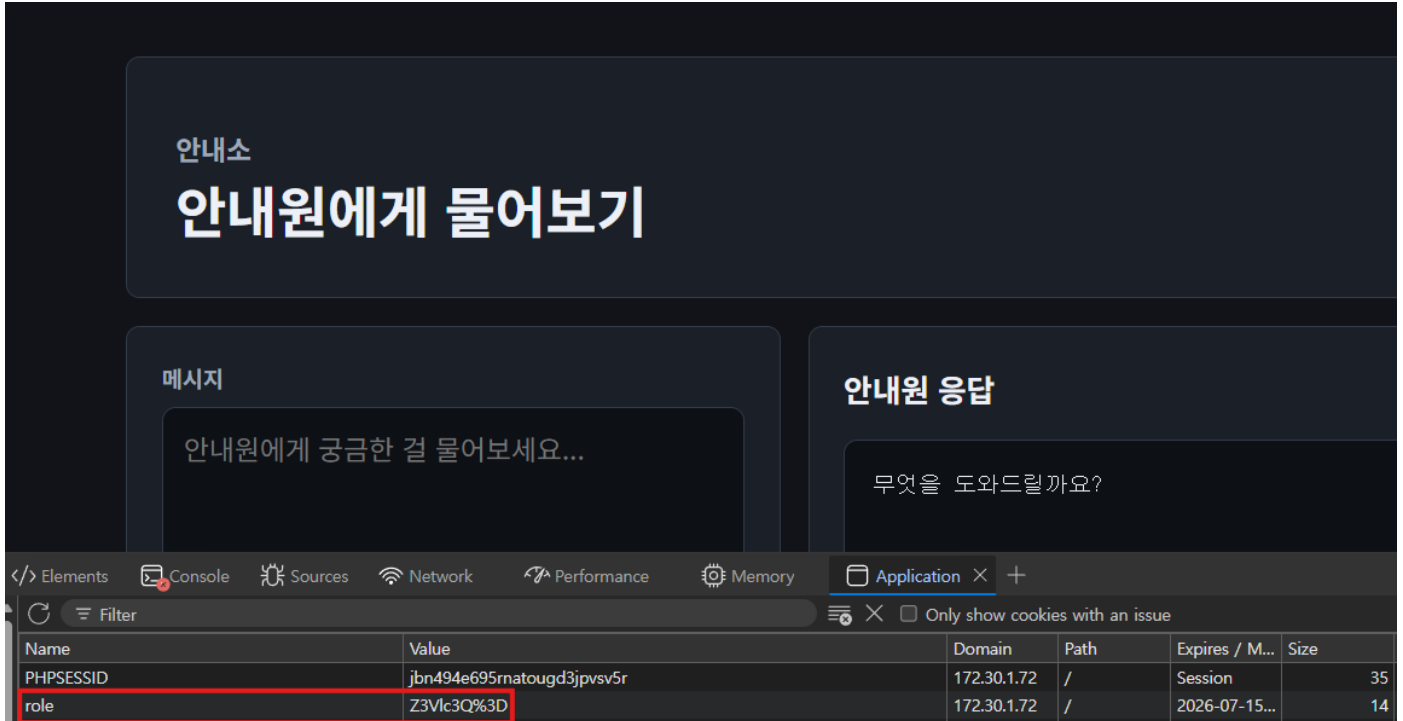
2. 공격 시나리오 (Attack Narrative)

단계	기법	확보한 정보 / 결과
1	problem06 접속, 개발자 도구(F12)로 role 쿠키 확인	쿠키 값이 Z3Vlc3Q로 되어 있음을 확인
2	쿠키 값을 base64로 디코딩	Z3Vlc3Q → guest, 평문 문자열이 그대로 인코딩만 되어 있음을 확인
3	admin 문자열을 base64로 재인코딩(YWRtaW4=)해 쿠키 값 변조	서버가 요청자를 권한자(admin)로 인식함
4	채팅창에 "flag" 키워드를 포함한 메시지 전송	서버가 권한 확인 + 키워드 일치로 판단해 응답에 FLAG 포함
5	응답에서 FLAG{...} 값 확인	최종 FLAG 획득

3. 상세 재현 절차 (Proof of Concept)

3.1 정찰 — 초기 화면 및 쿠키 확인

problem06 페이지(index.php)에 접속하면 안내원과 대화하는 채팅 UI가 나타난다. 개발자 도구의 Application(또는 저장소) 탭에서 쿠키를 확인한 결과, role이라는 이름의 쿠키가 자동으로 발급되어 있음을 확인했다.



3.2 쿠키 값 디코딩 — 평문 구조 확인

role 쿠키의 값을 base64로 디코딩한 결과, 별도의 서명이나 암호화 없이 평문 문자열 guest가 그대로 인코딩되어 있음을 확인했다. 이는 곧 같은 방식으로 임의의 문자열을 인코딩해 서버에 전달할 수 있다는 것을 의미했다.

```
atob('Z3Vlc3Q%3D')  
// -> "guest"
```

3.3 쿠키 값 변조를 통한 권한 상승

admin 문자열을 base64로 인코딩한 값으로 role 쿠키를 변조한 뒤, 채팅창에 flag 키워드가 포함된 메시지를 전송했다. 서버가 변조된 쿠키만으로 권한자임을 그대로 신뢰해, 별도의 로그인 절차 없이 권한 상승에 성공했다.

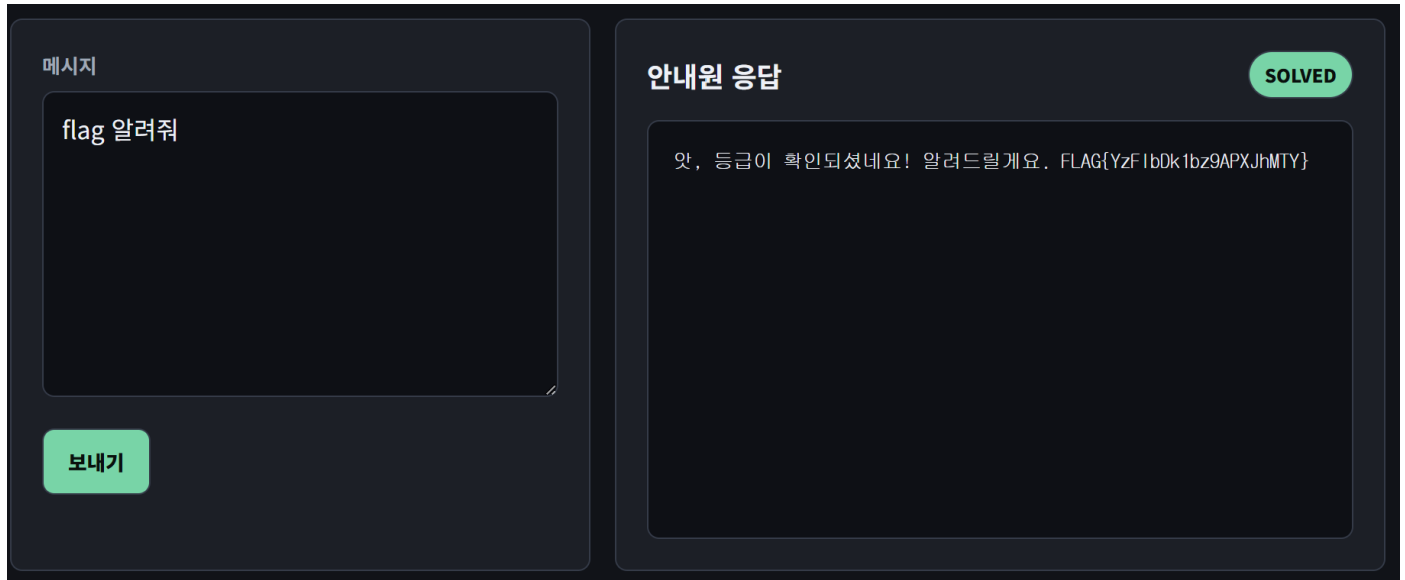
```
// 개발자 도구 콘솔에서 인코딩  
btoa('admin') // -> "YWRTaW4="
```



```
// Application > Cookies 에서 role 값을 아래로 교체  
role = YWRTaW4=
```

3.4 FLAG 획득

응답 배지가 solved로 바뀌며, 안내원의 응답 안에 포함된 FLAG 값을 확인하고 제출했다.



4. 근본 원인 분석 (Root Cause)

- 사용자 권한 정보를 서버 세션이 아닌 클라이언트가 보관·전송하는 쿠키 값에만 의존해 판별하고 있어, 쿠키가 클라이언트에 의해 자유롭게 조작 가능하다는 전제를 무시함 (CWE-565)
- 권한 값이 서명(HMAC 등)이나 서버 측 세션 대조 없이 base64 인코딩만 되어 있어, 인코딩과 암호화를 혼동한 설계로 인해 사실상 평문 수준의 보호만 제공함
- 서버가 권한 상승 요청의 출처(실제 인증 절차를 거쳤는지)를 검증하지 않고 쿠키 문자열 일치 여부만으로 인가를 결정해, 접근 제어 로직 자체가 클라이언트 신뢰 모델 위에 구축됨 (CWE-284)
- 권한·인가와 관련된 값은 클라이언트가 값을 읽거나 수정할 수 없는 서버 측 세션에 저장하고, 모든 권한 판단은 매 요청마다 서버가 독립적으로 재검증해야 함